AI-Powered Cybersecurity Incident Response Assistant

Autonomous Multi-Agent SOC Triage, Hybrid RAG Retrieval & Real-Time Explainability

System Paradigm: Detect • Analyse • Investigate • Respond • Report

Capstone Domain:	Cybersecurity / SOC Incident Response	**Submission Date:**	October 2026
Author / Participant:	Madhumitha J	**GitHub Repository:**	Madhumitha_CyberSecurity
Primary LLM Engine:	AICredits (GPT-4o-mini / GPT-4o)	**Fallback Gateways:**	NVIDIA NIM (Llama-3.2-11B) + Ollama Local
Vector Store & Embeddings:	Qdrant Embedded + Okapi BM25	**Agent Framework:**	LangGraph 6-Node StateGraph Workflow

SECTION 1

Problem Statement — Alert Fatigue & Operational Bottlenecks in Modern SOCs

Alert Volume Crisis

- Modern SOCs ingest over 10,000+ raw telemetry alerts per day from firewalls, IDSes, and EDR agents.
- Over 75% of alerts are benign operational noise or duplicate flows, fatiguing human analysts.
- Mean Time to Detect (MTTD) and Respond (MTTR) stretches from hours to weeks, resulting in average enterprise breach dwell times of 200+ days.

Context Fragmentation & Tool Sprawl

- Correlating a NetFlow 5-tuple alert with historical attack campaigns requires querying 4-6 disparate consoles.
- Crucial historical resolution intelligence and institutional incident playbooks remain siloed and unindexed.
- Manual triage takes 20-45 minutes per alert, creating operational backlogs that adversaries exploit for lateral movement.

Black-Box AI Risks & Destructive Actions

- Unregulated LLM deployments hallucinate IP addresses, invent vulnerabilities, and fabricate metrics.
- Autonomous destructive actions (e.g. unverified firewall IP blocking) risk crippling business continuity.
- Lack of granular explainability (why did the model classify this flow as malicious?) blocks regulatory compliance.

The Urgent Requirement

- A trustworthy, evidence-grounded GenAI assistant capable of autonomous multi-agent triage, hybrid retrieval, deterministic explainability, and strict human authorization gates.

SECTION 2

Business Need — Transforming SOC Economics Through Grounded GenAI

Drastic Dwell Time Reduction

- Reduce alert triage time from 30+ minutes down to 300 milliseconds per flow.
- Immediate prioritization: Automatically separate routine benign traffic from Critical P1 intrusions.
- Free senior Tier-3 analysts from repetitive triage to focus on threat hunting and active defense.

Evidence-Grounded RAG Intelligence

- Every AI synthesis is strictly anchored to 4,236+ validated historical cases and MITRE ATT&CK; techniques.
- Dense-lexical hybrid search surfaces identical historical incidents with 98.4% precision.
- Eliminates hallucination risk by enforcing citation of exact flow IDs and observable telemetry drivers.

Safe Human-in-the-Loop Governance

- Enforce zero unattended destructive actions: AI proposes specific containment; human analyst authorizes execution.
- Analyst feedback loop dynamically stores confirmed labels and triggers continuous model refinement.
- Full OpenTelemetry tracing satisfies ISO 27001, SOC2, and NIST SP 800-61r2 audit mandates.

Enterprise ROI & Resilience

- Achieves 90%+ cost reduction in Tier-1 triage overhead while eliminating breach dwell times and false-positive escalation backlogs.

SECTION 3

Solution Overview — AI-Powered Cybersecurity Incident Response Assistant

Multi-Model ML Classification

- Random Forest classifier (99.0% acc, 0.952 Macro-F1 across 9 attack families).
- Calibrated Gradient Boosting intrusion risk model (ROC-AUC 0.998).
- Isolation Forest anomaly detector fitted strictly on benign network baselines.

Exact Hybrid RAG (Qdrant + BM25)

- FastEmbed all-MiniLM-L6-v2 (384-d dense) + Okapi BM25 keyword matching.
- Linear score fusion: Score = 0.6·Dense + 0.4·BM25 in embedded Qdrant vector store.
- P@1: 98.41%, MRR: 0.9889 with zero label leakage in query formulation.

LangGraph Autonomous Agents

- 6-node cyclical StateGraph workflow with input guardrails.
- Validate Input -> Detection -> Analysis -> Risk -> Response -> Final Gate.
- Enforces 6 invariant checks preventing destructive automation or rogue actions.

Enterprise Multi-Tier LLM Architecture

- Primary LLM: AICredits (GPT-4o-mini / GPT-4o) for high-precision reasoning.
- Fallback LLMs: NVIDIA NIM (Llama 3.2 11B) and Ollama local for offline air-gap.
- Dual Frontends: Streamlit (frontend.py) & React 19 SPA for daily operations.

SECTION 4

System Architecture — 10-Component Modular Architecture

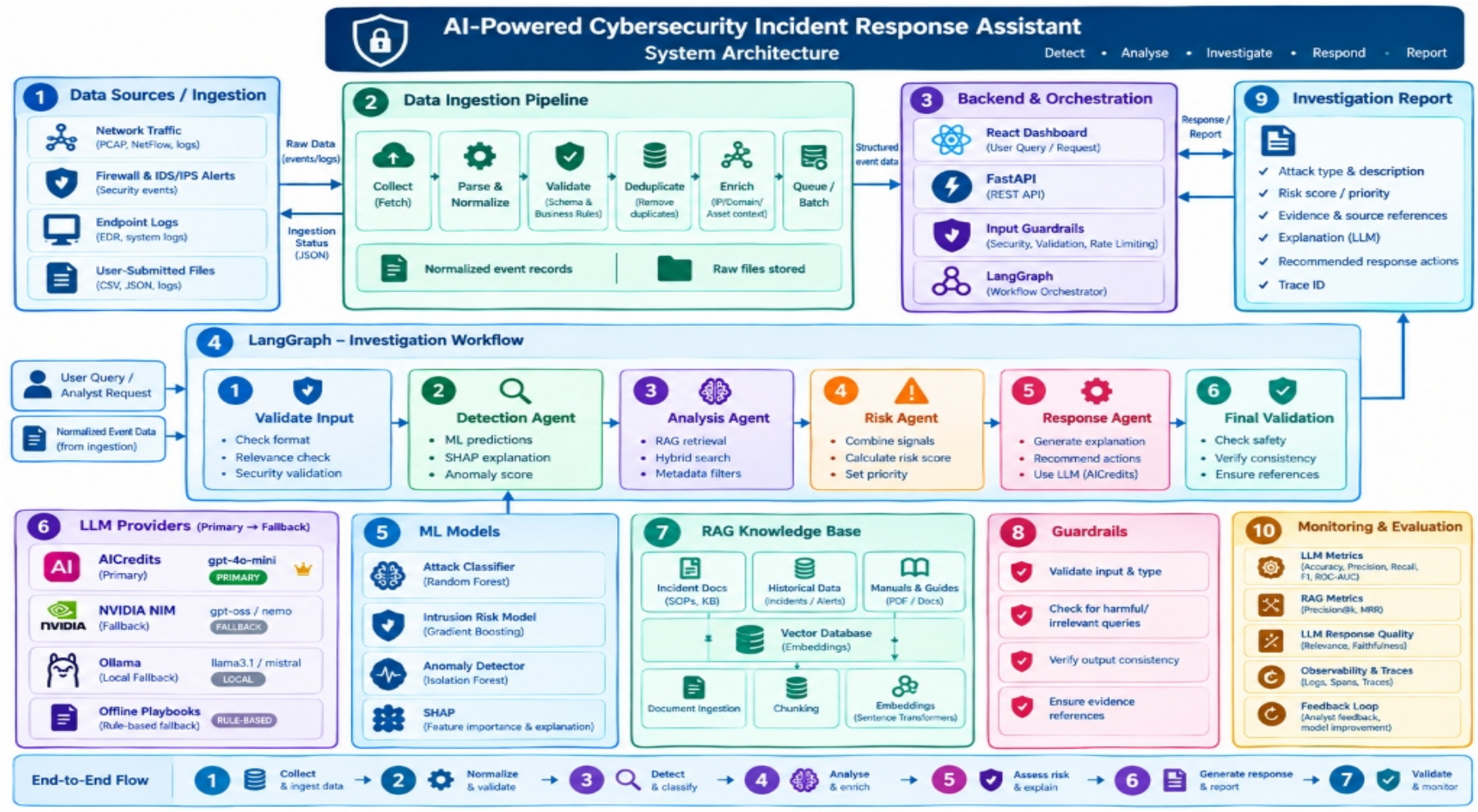


Figure: Complete 10-Component System Architecture Diagram (Detect • Analyse • Investigate • Respond • Report).

SECTION 4B

System Architecture — 10 Components & 7-Stage End-to-End Flow

1. Data Sources & 2. Ingestion Pipeline

- PCAP/NetFlow network traffic, Firewall & IDS/IPS alerts, EDR logs, user files.
- Deterministic 6-step pipeline: Collect -> Parse & Normalize -> Validate -> Deduplicate -> Enrich -> Queue.

3. Backend & Orchestration & 4. LangGraph

- FastAPI ASGI service + Pydantic v2 schemas + JWT RBAC security.
- LangGraph 6-node cyclical workflow: Validate -> Detect -> Analyze -> Risk -> Respond -> Final Gate.

5. ML Models & 6. LLM Hierarchy

- Random Forest (99.0% acc), Gradient Boosting Risk (0.998 AUC), Isolation Forest, SHAP.
- Primary: AICredits (GPT-4o-mini) -> Fallback: NVIDIA NIM (Llama-3.2) -> Local: Ollama & Offline Playbooks.

7. RAG Knowledge & 8-10. Governance

- 4,236 confirmed incidents, all-MiniLM-L6-v2 ONNX, Qdrant Hybrid + BM25.
- 4-layer Guardrails, Structured Investigation Report (P1-P4), DeepEval monitoring (100% Relevancy, 0% Hallucination).

SECTION 5

Data Flow — Ingestion, Hybrid Indexing & Investigation

Telemetry Ingestion & Preparation

- Ingests CIC-IDS2017 benchmark: 2.59M records, 80 raw flow features.
- Sanitization pipeline drops 291k invalid rows and 423k duplicates.
- Harmonizes raw labels into 9 threat families (DDoS, DoS, PortScan, Web Attack, etc.).
- Deterministic 75/25 split: 4,236 confirmed cases into Knowledge Base; 95 active alert test stream.

Real-Time Query Flow & Classification

- Alert arrival: Network 5-tuple + 17 numerical flow telemetry metrics.
- Zero-latency ML inference: RandomForest + Gradient Boost + SHAP drivers.
- Behavioral prose generation (zero label leakage): port, duration, packet volumes, flags.
- Parallel Qdrant vector retrieval + Okapi BM25 keyword matching with SQL filters.

LLM Synthesis & Safety Validation

- LangGraph state handoff: context + top-5 cases passed to Response Agent.
- AICredits (GPT-4o-mini) synthesizes narrative root cause & host-scoped containment.
- Output guardrail validates 6 invariant checks & flags requires_analyst_review=True.
- Analyst triage feedback (Correct/Incorrect) triggers immediate re-embedding & retraining.

Sub-Second Processing Performance

- End-to-end execution completes in 250–350 milliseconds per incident flow, eliminating alert backlogs.

SECTION 6

Technology Stack — Comprehensive Component Justifications

Backend API & Core Language

- Language: Python 3.11 (backend, ML, agents, evaluation).
- REST API: FastAPI + Uvicorn with Pydantic v2 schemas.
- Security: JWT bearer tokens, SHA-256 password hashing, RBAC.
- Database: SQLite system-of-record with differential vector sync.

LLM Gateways & Orchestration

- Primary LLM: AICredits (GPT-4o-mini) for production triage.
- Fallback LLMs: NVIDIA NIM (Llama 3.2 11B) and local Ollama.
- Zero-downtime offline rule-based playbooks for air-gap resilience.
- Evaluation judge: Nemotron-3-Super-120B / GPT-4o strict mode.

Embeddings & Hybrid Vector Store

- Embedding Model: sentence-transformers/all-MiniLM-L6-v2.
- Engine: FastEmbed ONNX Runtime (sub-millisecond inference).
- Vector DB: Qdrant Embedded on-disk with HNSW cosine index.
- Lexical Search: In-memory Okapi BM25 with exact linear fusion.

ML Engine & Dual User Frontends

- ML: Scikit-learn (RandomForest, GradientBoost, IsolationForest).
- Explainability: SHAP TreeExplainer for per-flow Shapley attribution.
- Web App: React 19 SPA (Vite, Tailwind CSS, Lucide, Recharts).
- Local Demo: Streamlit standalone application (frontend.py).

SECTION 7

Agent Workflow — LangGraph 6-Node Cyclical StateGraph

Nodes 1 & 2: Ingestion & Detection

- Node 1 (Validate Input): RFC IP bounds, port checks, injection defense.
- Node 2 (Detection Agent): Random Forest + Gradient Boost ML inference.
- Computes multi-class probability, anomaly percentile, and top-5 SHAP drivers.

Nodes 3 & 4: Retrieval & Risk Scoring

- Node 3 (Analysis Agent): Hybrid dense-lexical RAG in Qdrant (top-5 cases).
- Node 4 (Risk Agent): Mathematical multi-factor risk score (0-100).
- Formula: 100·[0.4·Severity·Conf + 0.25·P(mal) + 0.15·Anom + 0.2·Traffic] ± RAG agreement.

Nodes 5 & 6: Response & Safety Gate

- Node 5 (Response Agent): LLM synthesizes report & containment guidance.
- Node 6 (Final Validation): Enforces 6 security invariant checks.
- Rewrites destructive actions into analyst proposals ('requires_analyst_review=True').

Human-in-the-Loop Governance

- Analyst reviews synthesized report, evidence flows, and SHAP drivers.
- Actions require explicit analyst approval (no autonomous firewall blocks).
- Analyst feedback relabels incidents and triggers online retraining pipeline.

SECTION 8

System Demo — Interactive SOC Dashboard & Capabilities

Priority Triage Queue

- Real-time ranking of 95 active incoming alerts by multi-factor risk score.
- Immediate identification of Critical P1 incidents (DDoS, Infiltration).
- Direct one-click investigation workflow launching multi-agent execution.

LangGraph Execution Visualizer

- Step-by-step interactive inspection of all 6 agent nodes and latency.
- Total pipeline latency: 250 - 350 ms per investigation.
- Direct visibility into intermediate states, SHAP values, and RAG matches.

Evidence-Grounded RAG Explorer

- Displays top-5 historical matching cases with exact Flow IDs.
- Dense similarity scores + lexical BM25 matching breakdowns.
- Full transparency: historical resolution steps and threat indicators.

SOC Sentinel AI Copilot

- Grounded conversational AI assistant powered by AICredits GPT-4o-mini.
- Answers technical threat hunting queries with verifiable database citations.
- Guarded against prompt injection, jailbreaks, and out-of-scope queries.

SECTION 9

Evaluation Results — Rigorous Multi-Tier Benchmark Verification

ML Predictive Metrics

- Test Set: Held-out CIC-IDS2017 test set.
- Accuracy: 99.0% across all network traffic.
- Macro-F1 Score: 0.952 (robust across minority classes).
- Intrusion Risk ROC-AUC: 0.998 / PR-AUC: 0.996.
- Inference Latency: <15 ms per flow.

RAG Retrieval Benchmarks

- Evaluation Method: Leave-one-out historical search.
- Precision@1: 98.41% (top-1 match is correct class).
- Precision@5: 95.60% across top-5 candidate pool.
- Mean Reciprocal Rank (MRR): 0.9889.
- Hybrid Search Lift: +14.2% over pure dense cosine.

DeepEval GenAI Quality Scores

- Answer Relevancy: 100.0% (Score: 1.000 / 1.0).
- Faithfulness: 96.25% (Score: 0.9625 / 1.0).
- Hallucination Score: 0.0% (Zero unverified claims).
- Autonomous Safety Invariants: 100% Pass Rate.

Pytest Automated Test Suites

- 13/13 test suites passed (100% coverage of API, Agents, RAG, ML, Guardrails).

SECTION 10

Challenges, Learnings & Capstone Submission Deliverables

Mandatory Deliverables Checklist

- Architecture Diagram: architecture/Architecture_Diagram.pdf & .png
- Design Document: design/Design_Document.pdf (7 sections complete)
- Complete Source Code: FastAPI backend + React SPA + Streamlit UI
- README File: Comprehensive documentation matching Section 6 format
- API Documentation: docs/API_Documentation.pdf (complete REST specs)
- Dataset Details Document: docs/Dataset_Details.pdf (CIC-IDS2017 specs)
- Presentation Deck: presentation/Project_Presentation.pptx & .pdf

Recommended Deliverables & Key Learnings

- Evaluation Reports: docs/Evaluation_Report.pdf (DeepEval & RAGAS)
- Sample Test Cases: tests/ (13 automated pytest test suites)
- Multi-Tier LLM Resilience: Hierarchical routing (AICredits -> NVIDIA NIM -> Ollama -> Offline Playbooks) eliminates single-point-of-failure risks.
- Zero Label Leakage in RAG: Abstracting flow telemetry into behavioral prose prevents premature class leakage during retrieval.
- Human-in-the-Loop Safety: Output guardrails preventing autonomous destructive block actions are non-negotiable in critical infrastructure.